



By Nitesh Singh

Job Ready Free Live Training To Become A

SOC

Analyst L1 For Free

Defronix Cyber Security → <https://defronix.com>



Think of Active Directory (AD) as the "Brain" or "Manager" of a company's computer network.

In a small home, you might have one laptop where you log in with your own password. But in a big company with 5,000 employees and 5,000 laptops, you can't manually create an account for every person on every single laptop. AD solves this by creating a **centralized phonebook** where everyone's identity is stored once, and they can use it to log into any computer in the company.

The Core Concept: Identity & Access

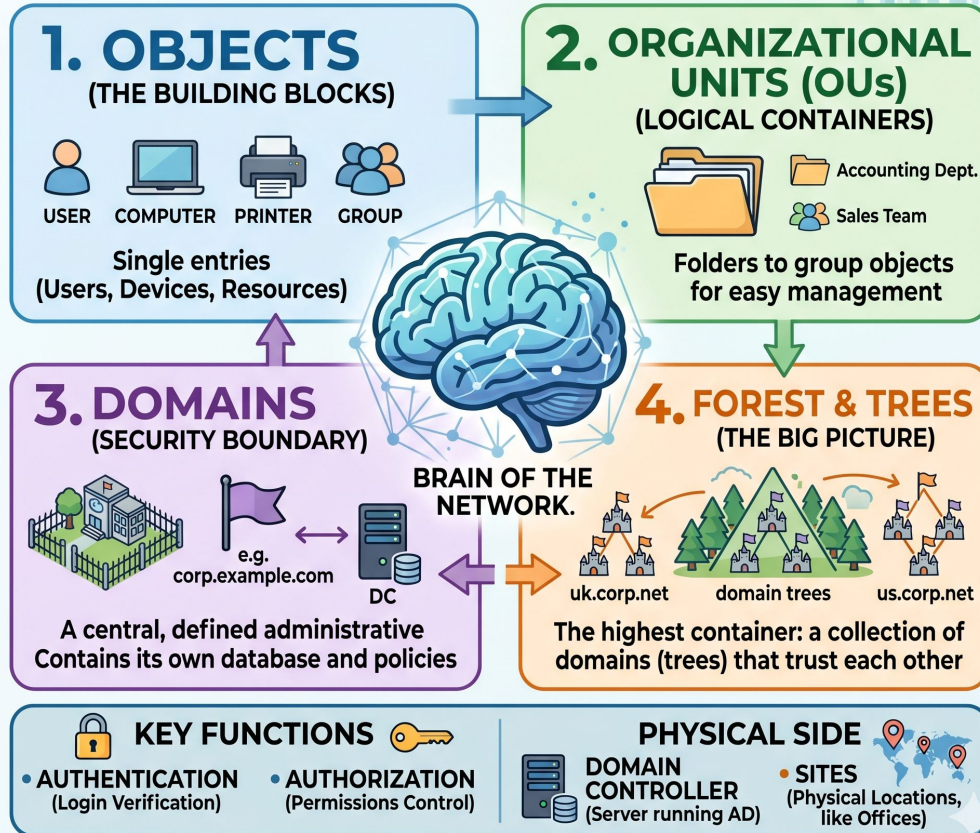
At its heart, AD does two things:

- **Authentication:** Verifying you are who you say you are (e.g., "Yes, this is John Doe's password").
- **Authorization:** Checking if you are allowed to do something (e.g., "John is allowed to use the HR printer but NOT the Finance folder").



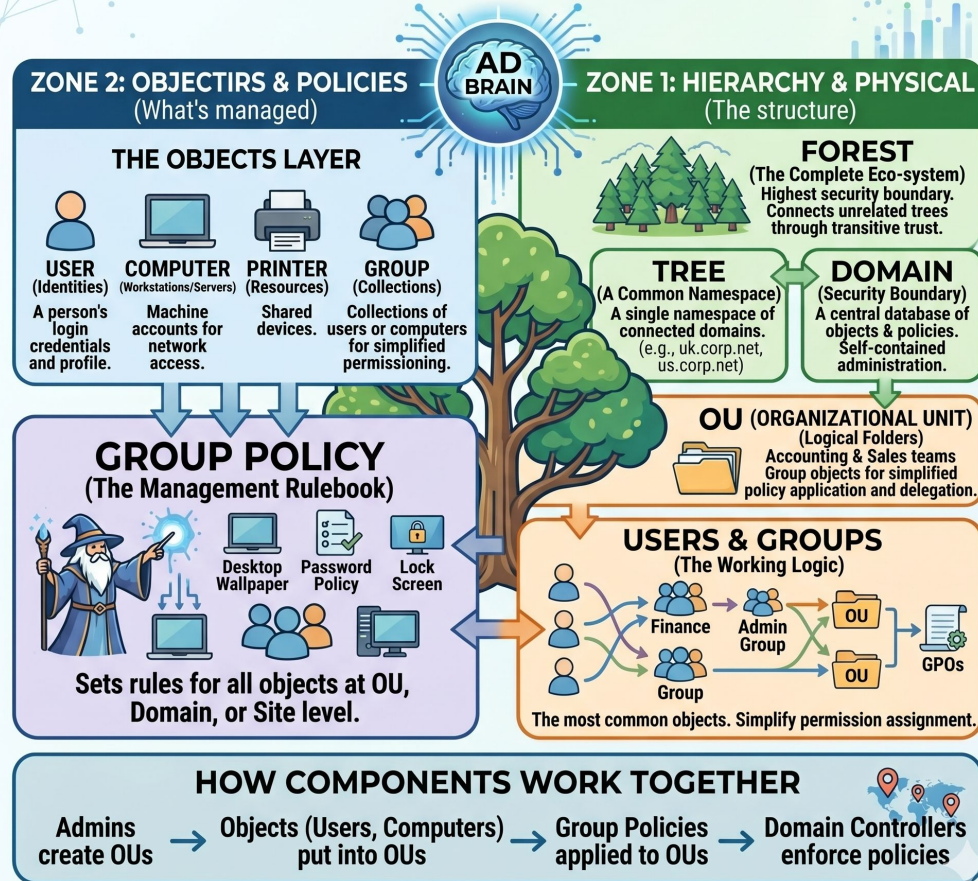
UNDERSTANDING ACTIVE DIRECTORY

The Business Network's Digital Directory





THE ACTIVE DIRECTORY ECOSYSTEM EXPLAINED





The Logical Structure (How it's Organized)

To keep things neat, AD uses a hierarchy that looks like an upside-down tree.

Objects

The smallest unit. An object is a "thing" in the network.

- **Users:** People who log in.
- **Computers:** The actual machines.
- **Printers/Shared Folders:** Resources people need to use.

Organizational Units (OUs)

Think of these as **folders**. You put your "Objects" inside OUs to stay organized. For example, you might have an OU for "Accounting" and another for "Sales."

Domains

This is the main "container." It's a boundary for security. Usually, a domain looks like a website address, like `corp.apple.com`. Everything inside this domain follows the same rules.

Trees and Forests

- **Tree:** A group of domains that share the same name (e.g., `sales.apple.com` and `uk.apple.com` are in the same "apple.com" tree).
- **Forest:** The highest level. It is a collection of trees. If Apple bought another company called "Beats," they might put both the `apple.com` tree and the `beats.com` tree into one big "Forest" so they can talk to each other.



The Physical Structure (The Hardware)

While the logical structure is how you see it, the physical structure is where the **data actually lives**.

- **Domain Controller (DC):** This is the **Server** that runs the AD software. It holds the database (a file called `ntds.dit`). When you type your password, your computer sends it to the DC to ask, "Is this correct?"
- **Sites:** These represent physical locations (like an office in New York and another in London). AD uses "Sites" to make sure a user in London talks to a London server instead of waiting for a slow signal from New York.

How it Works: The "Special Sauce"

Active Directory relies on three main "languages" (protocols) to work:

1. **DNS (Domain Name System):** This is the GPS. It helps computers find where the Domain Controller is on the network.
2. **LDAP (Lightweight Directory Access Protocol):** The "search language." It's how AD looks up information (e.g., "Find the email address for Jane Smith").
3. **Kerberos:** The "ticket system." Once you log in, Kerberos gives you a digital "ticket" so you don't have to keep re-typing your password every time you open a new file or printer.



Group Policy (The Boss Mode)

One of the most powerful features of AD is **Group Policy Objects (GPOs)**. This allows an IT person to change settings for thousands of computers at once.

- **Example:** "Make sure every computer in the Sales department has the company logo as the wallpaper and locks the screen after 5 minutes of inactivity."
- Without AD, you'd have to walk to every desk. With AD, you click one button.

Term	Simple Analogy (Summary)
Object	A single contact in your phone.
OU	A folder (e.g., "Work Contacts").
Domain	Your entire phone's contact list.
Forest	Multiple phones synced together.
Domain Controller	The actual phone hardware storing the data.



TGT (TICKET GRANTING TICKET)

WHAT IT IS:



"MASTER WRISTBAND"
(e.g., from a theme park)

Your master identity proof.
Proves you are logged in.
Encrypted by KDC.

WHAT'S INSIDE (THE TGT ENVELOPE):



HOW IT'S USED:



SESSION KEY (THE SECRET CODE)

WHAT IT IS:



SECRET HANDSHAKE

A unique, temporary, disposable password for one secure conversation.
Keeps messages secret.

WHAT'S INSIDE (THE SESSION KEY):

1aBc2DxYz9
RGhj dCaMzW

**RANDOM
RANDOM CODE**



HOW IT'S USED:



KEY RECAP: TGT = YOUR ID. SESSION KEY = YOUR PRIVATE CONVERSATION CODE.

TGT (Ticket Granting Ticket) & The Session Key



The **TGT** is your "Master Pass." In the Theme Park analogy, this is the **wristband** you get at the front gate.

- **What it contains:** It holds your username, your IP address, and a "valid until" timestamp (usually 10 hours).
- **The Secret:** The TGT is **encrypted** by the Domain Controller using a secret key that *only* the Domain Controller knows.
- **Why it exists:** Because it is encrypted this way, you can't "fake" it or edit it. When you show it back to the DC later to ask for access to a file, the DC decrypts it and says, *"Yep, I recognized this. I issued this to John 2 hours ago, so he's still legit."*

The **Session Key** is like a **temporary, disposable password** created just for one conversation.

Think of it like a "Secret Handshake" that the Domain Controller invents and teaches to both you and the server you want to talk to.

- **The Problem:** If you and a server talk over the network, a hacker might be listening. You don't want to use your *real* password to lock those messages.
- **The Solution:** The DC creates a **Session Key** (a random string of numbers). It sends one copy to you and another copy to the Server.
- **How it works:** Now, you and the Server can encrypt your messages using this random key. Even if a hacker steals the Session Key, it expires in a few hours, so your real password remains safe and untouched.

How they work together (The "Two Envelope" Trick)



When the Domain Controller sends you the response in **Step 2** of next diagram, it actually sends **two envelopes**:

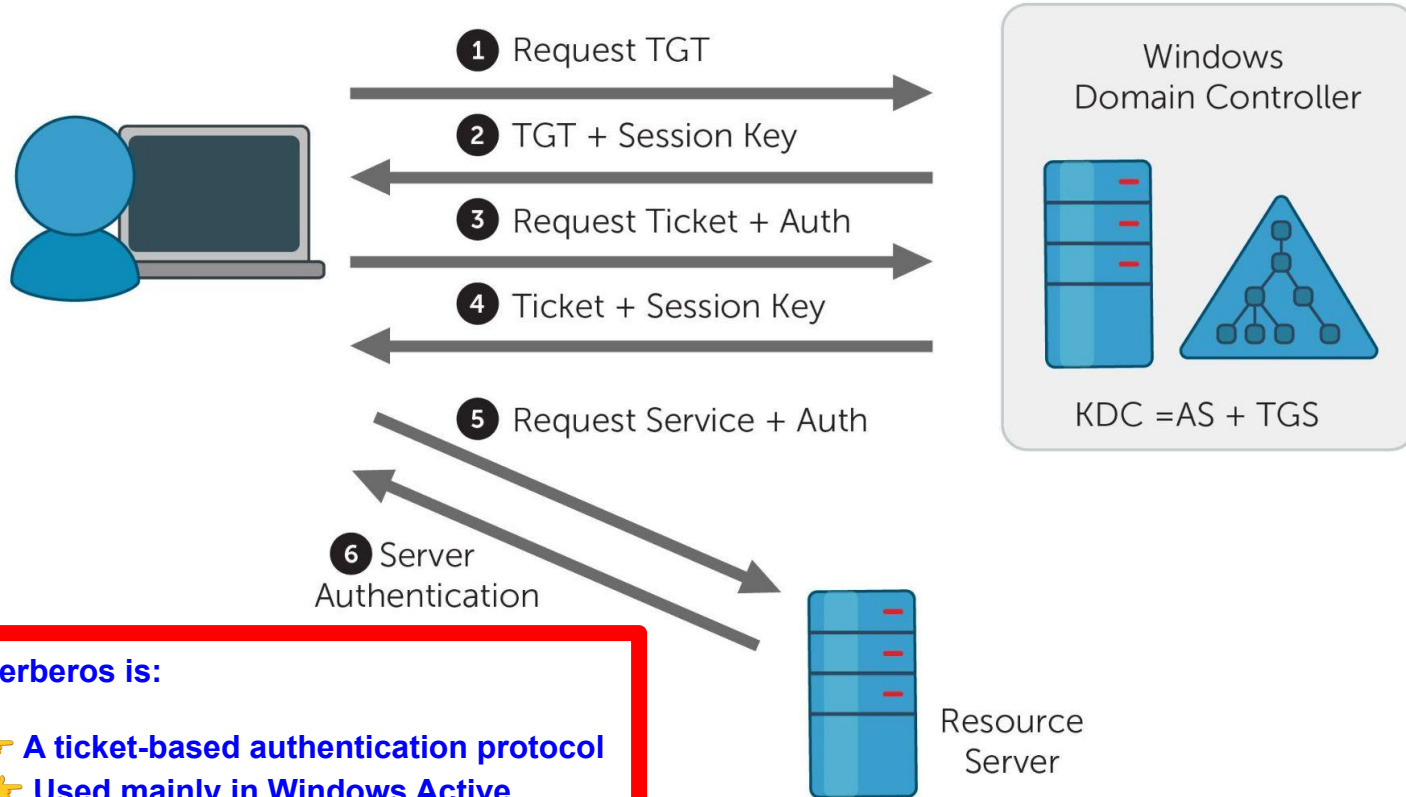
1. **Envelope A (The TGT)**: This is locked. You cannot open it. You just hold onto it to show the "Security Guard" later.
2. **Envelope B (The Session Key)**: This is locked with a key derived from *your password*. Since you know your password, you can open this and get the Session Key inside.

A common mistake is thinking the TGT lets you access files directly. It doesn't! The TGT only lets you talk to the "Ticket Office." You still need a **Service Ticket** (Step 4 in your image) to actually open a folder or use a printer.

Feature	TGT (The Wristband)	Session Key (The Secret Handshake)
Who makes it?	The Domain Controller (KDC).	The Domain Controller (KDC).
Who can read it?	Only the Domain Controller.	Both You and the Server .
Purpose	To prove you are already logged in.	To encrypt the conversation so no one can "eavesdrop."
Lifespan	Usually 10 hours.	Very short (often expires after the task is done).



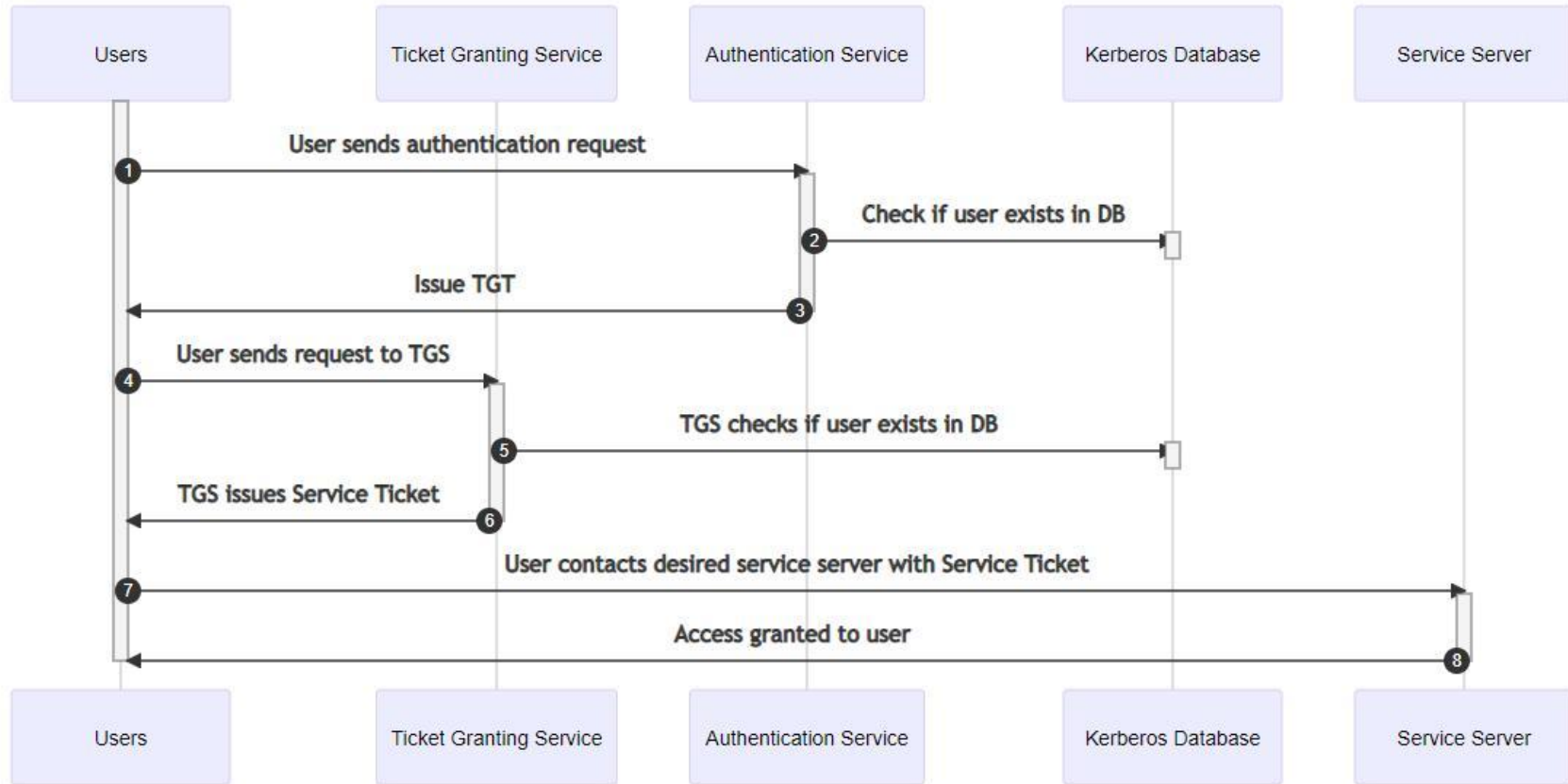
Kerberos Authentication in AD



Kerberos is:

- 👉 A ticket-based authentication protocol
- 👉 Used mainly in Windows Active Directory environments

Kerberos Authentication (in detail)



Kerberos Authentication (in detail)



The previous diagrams explained **Kerberos**, which is the "Security Guard" of Active Directory. To make it simple, let's imagine you are going to a massive **Theme Park (The Network)**.

In this theme park, you don't carry cash or your ID to every ride. Instead, you use **Tickets**.

The 3 Players

1. **You (The Client)**: The person trying to log in and use a file or printer.
2. **The Ticket Office (Domain Controller / KDC)**: The only place that knows your password.
3. **The Ride (Resource Server)**: The file server or printer you want to use.

Key Terms in the Image:

- **KDC (Key Distribution Center)**: The "Ticket Office" mentioned in next slide.
- **AS (Authentication Service)**: The guy who gives you the wristband.
- **TGS (Ticket Granting Service)**: The guy who gives you the ride tickets.

The 6 Steps Process (kerberos auth)



Step 1 & 2: Getting your "Entry Pass"

- **1. Request TGT:** You type your password. Your computer sends a message to the "Ticket Office" saying, "Hey, I'm John. Here is proof of my identity."
- **2. TGT + Session Key:** The Ticket Office checks its database. If you're legit, it gives you a **TGT (Ticket Granting Ticket)**.
 - *Analogy:* This is like a **hand stamp** or a **wristband**. It doesn't let you on a ride yet, but it proves you paid to get into the park.

Step 3 & 4: Getting your "Ride Ticket"

- **3. Request Ticket + Auth:** You want to open a "Finance Spreadsheet" (The Ride). You show the Ticket Office your "wristband" (TGT) and say, "I'd like to ride the Finance Rollercoaster, please."
- **4. Ticket + Session Key:** The Ticket Office checks if you're allowed on that ride. If yes, it hands you a **Service Ticket**.
 - *Analogy:* This is a **specific ticket** just for that one ride.

The 6 Steps Process (kerberos auth)



Step 5 & 6: Enjoying the Ride

- **5. Request Service + Auth:** You go to the Finance Server and hand over your **Service Ticket**.
- **6. Server Authentication:** The server looks at the ticket, sees it was signed by the official Ticket Office, and says, "Welcome aboard!" You can now see your files.

Why do we do this?

- **Security:** Your actual password is only sent **once** (at the very beginning). After that, only "tickets" move across the network. If a hacker is listening, they can't steal your password because they only see temporary tickets.
- **Speed:** Once you have that "wristband" (TGT) in Step 2, you don't have to type your password again for the rest of the day, even if you want to access 50 different printers or files!



1. Pass-the-Hash

Use NTLM hash instead of password

2. Kerberoasting

Steal Kerberos service tickets

3. Golden Ticket

Forge Kerberos tickets

4. DCSync

Steal password hashes from DC

5. Privilege Escalation

User added to Domain Admins



AD LOGS (SOC IMPORTANT)

Event ID	Meaning
4624	Login
4625	Failed login
4672	Admin privileges
4720	User created
4732	User added to group

FINAL SOC MINDSET

When investigating AD:

Don't ask:

✗ "What command ran?"

Ask:

Why was it run?

Who executed it?

What did it access?

Did it move laterally?